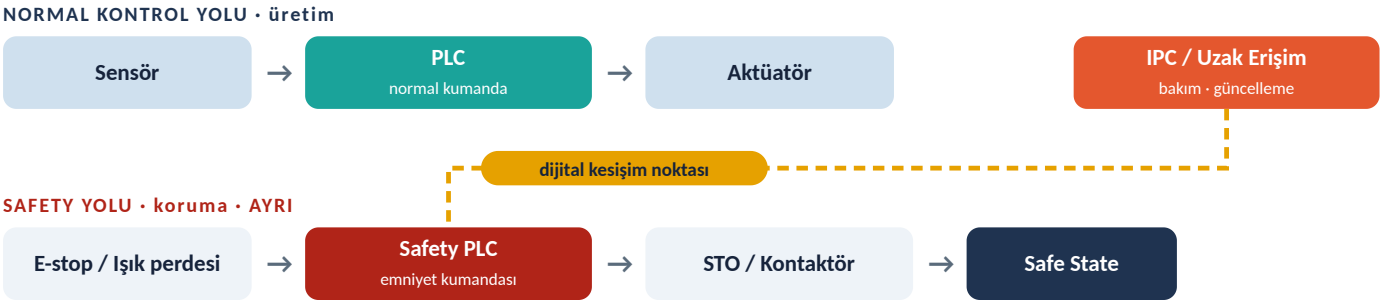
Safety Architecture

Çıktı: Safety Function Map

Ad Soyad | Grup | Tarih

Kavram: Emniyet fonksiyonu, insanı koruyan fonksiyondur ve **ayrı bir safety yolunda** yaşar (E-stop → Safety PLC → STO). Gerekli güvenilirliği (PLr/SIL) riskle orantılıdır — ve bu güvenilirlik, **dijital bir konfigürasyona** bağlıdır.



Görev — sırayla cevaplayın

1. Bu makinede tehlike nedir? İnsan neyden zarar görür?

   Kamera yanlış kesim koordinatı üretirse veya malzeme kayarsa operatör sıkışan parçayı düzeltmek için kesici bölgeye yaklaşabilir.

2. Safety function (emniyet fonksiyonu) hangisidir?

   Koruyucu erişiminde tehlikeli kesim ve besleme hareketlerini durdurmak, otomatik yeniden başlamayı engellemek.

3. Safety-related control system nerede? Şemada işaretleyin.

   Koruyucu algılayıcılar → emniyet mantığı → kesici ve besleme hareketini güvenli duruma getiren elemanlar.

4. Normal PLC ile Safety PLC farkı nedir?

   Normal PLC kesim sırasını yönetir; emniyet sistemi tehlikeli hareketi önler. Gerçek mimari doğrulanmalıdır.

5. PLr / SIL neden var? Bu fonksiyon için neden önemli?

   Kesici kaynaklı ağır yaralanma riskine karşı gereken emniyet performansını belirlemek için.

6. Safe state (güvenli durum) nedir?

   Kesici ve tehlikeli besleme hareketleri durmuş, beklenmedik yeniden başlama engellenmiş durum.

7. Safety function hangi dijital bağımlılıklara sahip?

   Kamera ölçümü, enkoder, PLC programı, sürücü parametreleri ve iş emri verisi.

8. Siber müdahale hangi noktadan bu fonksiyonu bozar?

   Kesim koordinatını, hareket parametrelerini veya emniyet yapılandırmasını değiştirebilen yetkisiz erişim yolundan.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

LABORATUVAR 2 · UKM-OPT · Otomatik Boy Kesme Makinesi

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad | Grup | Tarih

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

PLC · HMI · Robot kontrolörü · **Safety PLC** · SCADA istemcisi · Mühendislik istasyonu · Uzak servis erişimi · Ofis ağı (ERP/e-posta)

1. Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

   Z1 Emniyet: Emniyet kontrolörü ve koruyucu algılayıcılar. Z2 Makine kontrolü: PLC, sürücüler, besleme mekanizması.

   Z3 Optimizasyon: Kamera, görüntü işleme, HMI. Z4 Bakım DMZ'si: Jump server ve güncelleme sistemi.

   Z5 Dış ağ: İnternet ve bulut telemetrisi.

2. Safety PLC'yi hangi bölgeye koydunuz — neden?

   Z1 Emniyet bölgesine; en kritik varlıktır, diğer bölgelerden ayrı tutulur. Uzak bakım modülü Z4'te olmalı; doğrudan internete veya emniyet ağına açık kalmamalı.

3. Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

   Her bölge geçişinde: izin listesi, kaynak/hedef kısıtlaması, kayıt ve yalnızca gerekli protokollere izin.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	Jump server — doğrudan erişim kapatılır
Tünel?	Açık / VPN	VPN — trafik şifreli tünelden geçer
Kimlik?	Parola / MFA	MFA — parola tek başına yetmez
Hesap?	Paylaşılan / Kişisel	Kişisel — kimin ne yaptığı izlenebilir
Kayıt?	Yok / Tam oturum kaydı	Tam oturum kaydı — adli analiz için
Zamanlama?	Sürekli açık / Varsayılan kapalı	Varsayılan kapalı — ihtiyaç anında açılır

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad | Grup | Tarih

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
Kesim planı değiştirilir; yanlış koordinat tehlikeli hareket veya operatör müdahalesi doğurur.	2	3	2	12	Yüksek
Enkoder verisi ile kamera ölçümü uyuşmaz; sistem yanlış malzeme konumunda kesime izin verir.	2	3	2	12	Yüksek
Elektrik kesintisi sonrası eski iş emri ve eski çevrim durumu geri yüklenir.	1	3	1	3	Düşük skor, zorunlu inceleme

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

   İlk iki senaryo; çünkü doğrulanmamış konum bilgisinin fiziksel kesim hareketine dönüşmesi riski vardır.

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

   Evet: yeniden başlatma senaryosu. Düşük olasılık, ağır yaralanma ihtimalini ortadan kaldırmaz; ayrı test ve aksiyon kaydı gerekir.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

LABORATUVAR 4 · UKM-OPT · Otomatik Boy Kesme Makinesi

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad | Grup | Tarih

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

İnternet → uzak bakım modülü → makine kontrol ağı.

HEDEF (beş ilkeyle yeniden tasarlayın)

İnternet → VPN/MFA → jump server → izinli bakım arayüzü.

Beş ilke: aracı, VPN, MFA, kişisel hesap, kayıtlı ve süreli erişim.

Görev B — functional safety köprüsü

1. Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

   Emniyet yapılandırmasına veya tehlikeli hareket komutlarına erişebiliyorsa etkilenebilir; bu bağımsızlık test edilmelidir.

2. Emniyet fonksiyonunun kontrol sisteminden bağımsız çalışması için GEREKSİNİMİ yazın (çözümü değil).

   “Uzaktan bakım erişimi, kamera veya üretim PLC'si üzerinden emniyet fonksiyonlarının devre dışı bırakılmasına ya da doğrulanmamış tehlikeli harekete yol açmamalıdır.”

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.

LABORATUVAR 5 · UKM-OPT · Otomatik Boy Kesme Makinesi

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad	Grup	Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Henüz bilinmiyor. CVE kimliği yer tutucu; gerçek bileşen, sürüm ve erişilebilirlik doğrulanmalı.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Fiziksel emniyet etkilenmişse güvenli duruş uygulanır. Karar yalnızca CVSS puanına göre verilmez.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce aynı sürüm ve donanımı temsil eden test ortamında; ardından kontrollü bakım penceresinde.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   PLC, sürücü veya emniyet parametreleri değişiyorsa ilgili fonksiyonlar yeniden doğrulanır.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Etkilenen servisi izole et, uzaktan erişimi kapat, değişiklikleri izle ve üreticiyle düzeltme planı oluştur.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

LABORATUVAR 6 · UKM-OPT · Otomatik Boy Kesme Makinesi

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad	Grup	Tarih

Senaryo: Saat **10:15**. Servis hesabında yetkisiz erişim tespit edildi. PLC konfigürasyonu değişmiş olabilir. Makine hâlâ çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

   Makineyi güvenli duruma al; OT güvenlik ekibini ve emniyet sorumlusunu çağır; şüpheli oturumu kesip kanıtları koru.

2. **İlk 2 saat:** Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?

   PLC ve emniyet yapılandırmalarını onaylı sürümlerle karşılaştır. Oturum kayıtlarını, sürücü parametrelerini ve kamera loglarını koru. Şüpheli hesabı iptal et.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

   Ürün, olay zamanı, etkilenen bileşenler, olası fiziksel etki ve alınan önlemleri hazırla. CRA bildirim koşullarını değerlendir.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

   Saldırı yolunu, kök nedeni, etkiyi ve düzeltici önlemleri teknik ekip ile ürün güvenliği sorumlusu birlikte belgeler.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?
   Tüm yapılandırma farkları, ağ ve oturum logları, test sonuçları ve olay kanıtları korunur. CRA'nın nihai rapor süreleri olay türüne göre ayrıca değerlendirilir; 14 gün her olay için genel son rapor süresi değildir.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.